Highlights

Lateral Phishing as a Violation of the Organizational Communication Graph: Cascade Dynamics and Leak-Aware Evaluation

Kamil Warpechowski, Bogdan Księżopolski

- Lateral phishing leaves a receiving-side wave on the communication graph.
- The cascade signal degrades less than volume detection under stealthy attacks.
- A time-shuffle control shows the advantage is temporal, not topological.
- The regime-level contrast replicates on Enron and two SNAP graphs.
- Base-rate arithmetic makes the detectors triage instruments, not autonomous defenses.

Lateral Phishing as a Violation of the Organizational Communication Graph: Cascade Dynamics and Leak-Aware Evaluation

Kamil Warpechowski[a,b,*], Bogdan Księżopolski[a]

[a]Kozminski University, Warsaw, Poland
[b]NASK National Research Institute, Warsaw, Poland

ARTICLE INFO

Keywords:
lateral phishing
Business Email Compromise
organizational communication graph
cascade dynamics
temporal graph networks
leak-aware evaluation

Abstract

Modern email filters detect mass phishing with high accuracy (∼98%) from content and reputation, yet the residual traffic—spear phishing and Business Email Compromise (BEC)—is the most costly. Its hardest case is lateral phishing from a compromised internal account: the sender is a known contact, the address is real, and the content can be clean. We argue that such an attack is a violation of the organization's communication graph in time. The compromised account writes off-rhythm and, decisively, propagates, so the cascade leaves a receiving-side wave signature that no single message reveals.

The main result is that this signature degrades far less than volume under a stealthy attacker. Against an attacker who spreads the sends over time, volume-based detection—the class of methods deployed in practice—collapses below the random baseline (AUC 0.44), while a temporal graph network reading the receiving side degrades less and stays above chance (AUC 0.60); the advantage vanishes under a time-shuffle control, and the regime-level contrast replicates in direction on three real communication graphs (Enron, `email-Eu-core`, `CollegeMsg`). We also mark the boundary: a single-recipient attack without propagation is invisible to every detector.

The methodological contribution is a leak-aware evaluation protocol—matched design, causal time-shuffle control, inductive organization split, label-noise audit—with explicit base-rate accounting: at a realistic prevalence each detected attack comes with hundreds of false alarms, so detectors of this class are triage instruments, not autonomous defenses. The work reframes lateral phishing as a measurable property of the communication graph: measurable, though not yet operationally solved.

1. Introduction

A mailbox is compromised on a Monday morning. Before noon, its owner's contacts in two departments and in a partner firm receive a short, plausible message with a link, each from a colleague they correspond with every week; some of them click, and an hour later their own contacts receive the same message. Nothing in any single message betrays the deception (Butavicius, Taib and Han, 2022; Sturman, Auton and Morrison, 2025). This is *lateral* phishing: a campaign sent from a genuinely compromised internal account, which Ho, Cidon, Gavish, Schweighauser, Paxson, Savage, Voelker and Wagner (2019) characterized at scale as attacks that reach many recipients inside and around the organization. FBI IC3 reports show that Business Email Compromise (BEC), of which lateral phishing is the inside-out variant, caused adjusted losses of approximately $2.9 billion in 2023 (Federal Bureau of Investigation, 2024). The sender is a known contact, the address is real, and the content is typically clean; the deception lies in *who* sends *when*, and in what happens next.

Phishing detection is often framed as an almost solved problem. Modern email filters, built on content and reputation, classify mass campaigns at ∼98% accuracy on typical benchmarks (Birthriya, Ahlawat and Jain, 2025; Tan, Chiew, Yong, Sze, Abdullah and Sebastian, 2020). However, this figure is misleading. Benchmark accuracy is dominated by the mass tail, while the targeted residual—spear phishing and BEC—is rare, drives a large share of financial losses (Cidon, Gavish, Bleier, Korshun, Schweighauser and Tsitkin, 2019; Ho et al., 2019) while largely evading content-based methods. This residual is the core of the problem, and lateral phishing is its hardest case: a

*Corresponding author
kamil.warpechowski@kozminski.edu.pl (K. Warpechowski); bogdan.ksiezopolski@kozminski.edu.pl (B. Księżopolski)
ORCID(s):

compromised account passes every check that looks at identity, reputation, or relationship, because all of them are genuine.

Our thesis is that lateral phishing is a violation of the organization's *communication graph in time*. We model the organization as a graph of who corresponds with whom, with a temporal rhythm for every account. A compromised account breaks this structure in two ways that no content filter can see. First, it writes outside its own rhythm. Second, and decisively, it propagates: the attack spreads as a cascade, and a cascade leaves a *receiving-side* signature—within a short window many accounts in one neighborhood are hit, each by a sender that was itself hit just before—which no single message reveals. This signature is what we detect, and pacing the sends weakens it far less than it weakens the sending-side burst. We are explicit about what this excludes: a single, surgical message from a compromised account to one recipient—the classic "CEO to CFO" transfer request—does not propagate and leaves no wave. It is the blind spot of every detector studied here; we measure it as such (Sec. 5.5), and it remains the domain of out-of-band process controls.

From a network-applications standpoint, corporate email is a networked service, and the organization's communication graph is an operational monitoring object of the same kind as the flow, alert, and provenance graphs used for intrusion and anomaly detection (Nayeri and Rezvani, 2026; Weng, Zhang, Zhu, Dou, Sun, Ye and Tian, 2024). The detectors studied here are accordingly designed as components of a SOC triage pipeline that scores events on that graph, not as a standalone mail filter.

We make the thesis testable through two research questions, each paired with a measurable sub-thesis.

RQ1 (signal). Can a compromised account, consistent with every static relation, be detected from cascade dynamics, and does the signal survive a stealthy attacker who spreads the sends over time? Sub-thesis T1: a temporal detector reading the receiving-side wave beats volume-based detection at low FPR and degrades less than volume detection under a stealthy attacker; the advantage vanishes under a time-shuffle control and transfers in direction to real topologies.

RQ2 (limits). What are the operational limits of the signal? Sub-thesis T2: the signal needs fan-out (a single-recipient attack is invisible), degrades gracefully under label noise and scale, and at a realistic base rate the detectors serve as a triage instrument rather than an autonomous defense.

The learning models used here—a temporal graph network with node memory and gradient boosting—are standard tools; the contribution is the framing of lateral phishing as a measurable violation of the communication graph and the evidence that the receiving-side signal depends on temporal order, transfers in direction to real graphs, and degrades less than volume detection under stealth. Graph-based detectors are easy to inflate: real-world anchors leak rhythm, degree, or community alignment with labels, and synthetic generators can favor a model class. Following Arp, Quiring, Pendlebury, Warnecke, Pierazzi, Wressnegger, Cavallaro and Rieck (2022) and the TESSERACT protocol (Pendlebury, Pierazzi, Jordaney, Kinder and Cavallaro, 2019), every result below is produced under a leak-aware protocol with causal controls and explicit base-rate accounting, which also yields an operational definition of what it means for a detector of this class to work.

Our contributions are as follows.

1. A formalization of lateral phishing as a temporal violation of the organizational communication graph, with a cascade threat model that covers both the naive blast and the stealthy, time-spread attacker (Section 3).
2. The receiving-side cascade signal as a detection invariant: a hierarchy of detectors of increasing temporal awareness, a causal time-shuffle control, and the headline result that volume-based detection collapses below the random baseline against a stealthy attacker while the receiving-side signal degrades less and stays above chance (RQ1; T1).
3. Replication of the mechanism on three real communication graphs (Enron, `email-Eu-core`, `CollegeMsg`), with the regime-level contrast reproduced in direction on each graph (RQ1; T1).
4. A leak-aware evaluation methodology and an operational definition of detection effectiveness for the targeted tail, with the limits stated explicitly: blind spot, label noise, scale, and base rate (RQ2; T2).

The rest of the paper is organized as follows. Related work (Sec. 2) precedes the model (Sec. 3), methodology (Sec. 4), and the case study with results (Sec. 5); the discussion (Sec. 6) follows. The complementary mode of targeted email—external impersonation of a role or authority, which requires knowledge beyond the communication graph—is out of scope here and is treated in a separate study.

2. Related Work

The review follows the chain of the thesis: lateral phishing and why content is insufficient (2.1), the graph and temporal-learning apparatus we borrow (2.2), and evaluation rigor (2.3), closing with the gaps (2.4).

2.1. Lateral phishing and BEC: why content is insufficient

Targeted attacks—spear phishing, whaling, and Business Email Compromise—differ from mass phishing in their personalization and context. A recent survey in *Computers & Security* systematizes the techniques and gaps of the area (Birthriya et al., 2025). Content-side classifiers, such as hybrid ensembles over email content and metadata (Bountakas and Xenakis, 2022), remain highly effective for the mass tail, but they inherit the content signal's blindness to clean-content, context-borne deception, and language models now make personalization cheap (Bethany, Galiopoulos, Bethany, Karkevandi, Vishwamitra and Najafirad, 2024). Ho et al. (2019) characterized lateral phishing from compromised accounts across 113 million emails and fixed an operational low-FPR threshold of <4 FP/million. Cidon et al. (2019) targeted payload-free BEC in production, and BEC surveys trace its evolution and cost (Atlam and Oluwatimilehin, 2023). What the effective methods share is a departure from content: per-sender behavioral profiles (Gascon, Ullrich, Stritter and Rieck, 2018; Stringhini and Thonnard, 2015), header and stylometry models (Duman, Kalkan-Cakmakci, Egele, Robertson and Kirda, 2016), as well as analysis of relay infrastructure (Luo, Young, Ho, Schweighauser, Katz-Bassett and Cidon, 2024) all catch mail from compromised legitimate accounts whose content reads as normal. Two families of behavioral defense transfer to a compromised mail account: *per-sender deviation* from the account's own profile, as in COMPA for social-network accounts (Egele, Stringhini, Kruegel and Vigna, 2013) and in behavioral models of email senders (Stringhini and Thonnard, 2015), of which a sudden spike in volume is the simplest form; and *causal-path* analysis, as in Hopper for lateral movement in enterprise login graphs (Ho, Dhiman, Akhawe, Paxson, Savage, Voelker and Wagner, 2021), which flags a hop to a rare target without a precursor that explains it. Transferred to email headers, both read the *sending* side. We show that a stealthy attacker who paces the sends largely removes that signal, and that the receiving side of the cascade is what remains.

2.2. Graph and temporal learning for communication graphs

The cascade invariant rests on a mature apparatus of graph learning, organized here into the threads that indicate what we borrow and what is missing for the communication graph of an organization.

On the foundations of inductive learning, modern graph networks learn node representations through neighborhood aggregation: the *inductive* GraphSAGE (Hamilton, Ying and Leskovec, 2017) (generalization to nodes unseen during training) and the attention-based GAT (Veličković, Cucurull, Casanova, Romero, Liò and Bengio, 2018) establish the paradigm; our *structural* (rather than identity-based) node features are a deliberately lightweight variant of it, to preserve inductive generalization (Xu, Ruan, Korpeoglu, Kumar and Achan, 2020; Hao, Cao, Fang, Xie and Wang, 2020). Link-prediction and scalable-embedding tasks (Zhang and Chen, 2018; Zhang, Qiu, Yi and Song, 2018) provide heads for classifying $(s \to v)$ events.

The invariant requires a model of time: the memory-based TGN (Rossi, Chamberlain, Frasca, Eynard, Monti and Bronstein, 2020), the attention-based DySAT (Sankar, Wu, Gou, Zhang and Yang, 2020), EvolveGCN (Pareja, Domeniconi, Chen, Ma, Suzumura, Kanezashi, Kaler, Schardl and Leiserson, 2020), ROLAND (You, Du and Leskovec, 2022), and streaming and spatio-temporal GNNs (Yu, Xia, Liu and Wu, 2023; Wang, Chen, Xu, Wu, Shen, Xuan and Yang, 2022; Nayebi Kerdabadi, Byron, Sun and Iranitalab, 2025; Behrouz and Seltzer, 2022) capture graph evolution. Temporal graph networks are by now standard instruments for operational network security, from security-alert prediction on real networks (Nayeri and Rezvani, 2026) to real-time anomaly detection on large-scale provenance graphs (Weng et al., 2024). Our TGN-lite is a minimal realization of this paradigm by design, allowing the time-shuffle control to isolate the *mechanism* rather than the capacity of the architecture.

The receiving-side wave has close relatives in the study of diffusion on networks. Outbreak detection asks where to place sensors so that a spreading process is caught early (Leskovec, Krause, Guestrin, Faloutsos, VanBriesen and Glance, 2007); source localization infers the origin of a diffusion from which nodes were reached and when (Pinto, Thiran and Vetterli, 2012; Shah and Zaman, 2011); cascade prediction and rumor detection learn from the shape and timing of a spread whether and how far it will go (Cheng, Adamic, Dow, Kleinberg and Leskovec, 2014; Vosoughi, Roy and Aral, 2018; Bian, Xiao, Xu, Zhao, Huang and Rong, 2020). These works model a spreading process on a known graph, as we do, but they classify the *cascade* or locate its *source*; we classify a single *event* by the state of its recipient's neighborhood, under a matched design in which every event is locally legitimate, and we ask specifically whether that signal survives an attacker who paces the spread.

The closest apparatus comes from fraud detection robust to *camouflage* and *class imbalance*: CARE-GNN (Dou, Liu, Sun, Deng, Peng and Yu, 2020), GraphConsis (Liu, Dou, Yu, Deng and Peng, 2020), PC-GNN (Liu, Ao, Qin, Chi, Feng, Yang and He, 2021a), H2-FDetector (Shi, Cao, Shang, Zhou, Zhou and Wu, 2022), GraphSMOTE (Zhao, Zhang and Wang, 2021), distribution-shift correction (Gao, Wang, He, Liu, Feng and Zhang, 2023; Tang, Li, Gao and Li, 2022), and the detection of money laundering and transactional fraud (Weber, Domeniconi, Chen, Weidele, Bellei, Robinson and Leiserson, 2019; Li, Gou, Liu, Hou, Li and Xiong, 2022a; Rayana and Akoglu, 2015). The broader graph-anomaly literature (Ding, Li, Bhanushali and Liu, 2019; Park, Kim, Han and Yu, 2020; Liu, Li, Pan, Gong, Zhou and Karypis, 2021b; Ma, Wu, Xue, Yang, Zhou, Sheng, Xiong and Akoglu, 2021; Zhang and Chen, 2021; Li, Qi, Zhao, Zheng, Cao, Dong and Yu, 2025), as well as predicting user dynamics and roles (Kumar, Zhang and Leskovec, 2019; Wu, Yuan, Lin, You, Chen, Chen and Zheng, 2020; Li, Xu, Xie, Zhou and Xuan, 2022b), provides techniques, yet operates on graphs of *transactions/reviews* and has yet to address the *propagation dynamics of a compromise* in a communication graph. Graph-based phishing detection has so far targeted mainly *web pages* and *transactions*: graph-theoretic and visual approaches for web pages (Tan et al., 2020; Lin, Liu, Divakaran, Dong, Ng, Jiang, Chen, Zhang, Lau and Dong, 2021; Abdelnabi, Krombholz and Fritz, 2020), attention over the email graph (Safran and Musleh, 2025), edge-feature GraphSAGE (Lo, Layeghy, Sarhan, Gallagher and Portmann, 2021), and propagation over URL–IP graphs (Guo, Wang, Yue, Sun and Hu, 2025; Li et al., 2022b). To our knowledge, the receiving-side dynamics of a lateral cascade have not been operationalized as a detection signal for corporate email.

2.3. Evaluation rigor: pitfalls and leak control

A central caution is that ML detectors in security are easily inflated by leaks, unfair splitting, and headline AUC in place of operational metrics (Arp et al., 2022); time-aware evaluation (TESSERACT) shows how temporal leakage distorts results (Pendlebury et al., 2019). These works motivate our leak-aware protocol and predictivity probe, which ask not how high the AUC is but whether the result transfers beyond a single corpus and whether it is an artifact of the generator. We use the same standard to define a method's effectiveness.

2.4. Gaps and positioning of the work

Several gaps emerge from the review. Detection of lateral phishing reads the sending side (volume, paths, sender profiles), which a patient attacker controls. The propagation dynamics of a compromise on the organization's communication graph have not been used as a detection signal, and evaluations rarely control for leaks or test transfer across topologies, so effectiveness tends to be ill-defined. The present work addresses these gaps: a temporal formalization of the communication graph, the cascade invariant with its causal control, replication on three real graphs, and a leak-aware methodology that defines effectiveness.

3. Model

The model formalizes the organization's communication graph in time and defines the invariant that a compromised account violates. All quantities here are variables; the numbers that instantiate them are stated in the Case Study (Sec. 5). Figure 1 gives an overview.

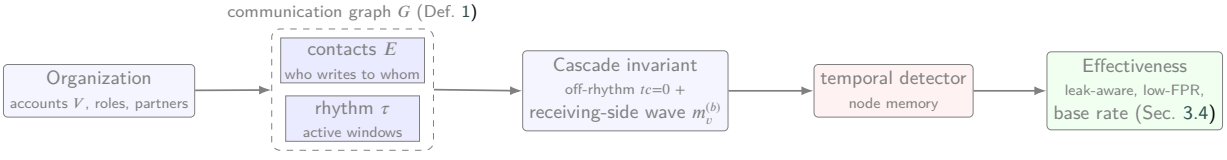


Figure 1: The model, general to detailed (left to right). An organization induces the communication graph G with a rhythm per account; a compromised account violates it by writing off-rhythm and by propagating, which leaves a receiving-side wave; a temporal detector with node memory reads that wave, and is judged by one *definition of effectiveness*.

3.1. The organizational communication graph

An organization's communication is relational and rhythmic: who corresponds with whom follows the organizational chart (supervisors, coworkers, business partners), and each account is active in characteristic windows of the week. Both facts are observable from mail headers alone, without content.

Table 1
Notation used throughout the paper. Concrete instantiations of the free parameters (N, T, p_{inf}, H) are given in the Case Study (Sec. 5).

Symbol	Meaning
$G = (V, E, \tau)$	organizational communication graph with rhythm
V	set of accounts (people/roles), $\lvert V\rvert = N$
E	contacts: $(s, v) \in E$ iff s corresponds with v
$\tau(s)$	temporal rhythm (active windows) of sender s
T	number of time buckets partitioning the period
b	a single time bucket, $b \in \{1, \dots, T\}$
$tc(s, v, t)$	temporal consistency of (s, v) at time t
s, v	sender, victim (recipient); s_0 the compromised account
p_{inf}	per-contact infection probability of a cascade
H	maximum cascade depth (hops)
K	number of carriers of a stealthy attacker (one send per bucket)
Z	static-GNN node embedding matrix, Eq. (1)
$d_v^{(b)}$	in-degree of node v within bucket b, Eq. (3)
$m_v^{(b)}$	temporal-GNN memory of node v after bucket b

Definition 1 (Organizational communication graph). *A communication graph is $G = (V, E, \tau)$, where V is the set of accounts (people/roles), $E \subseteq V \times V$ is the set of contacts ($(s, v) \in E$ iff s corresponds with v; induced by the organization's hierarchy, coworker, and partner relations), and $\tau : V \to \mathcal{T}$ assigns to every sender a* temporal rhythm*, the set of its active time windows. The temporal consistency of a message from s to v at time t is $tc(s, v, t) = \mathbf{1}[t \in \tau(s)]$.*

A message from a known contact in its rhythm, $(s, v) \in E$ and $tc = 1$, is the normal case. A known contact writing *off-rhythm*, $tc = 0$, is the canonical signature of a compromise: the relation is genuine, the timing is not. This single bit is weak on its own (legitimate mail also arrives off-hours, and an attacker with mailbox access can mimic the rhythm), which is why the invariant below reads the dynamics of the whole neighborhood rather than one message.

3.2. Threat model: the compromised account

The attacker has gained mailbox access to an internal account s_0 (the *patient zero*) and wants to deliver to victims messages classified as legitimate. From s_0 the attacker mails the account's own contacts; each recipient becomes a carrier with probability p_{inf} and propagates to its own contacts, up to depth H. The attack is therefore a *cascade* on G (Fig. 2 in Sec. 4). The term follows Ho et al. (2019), who coined *lateral phishing* for phishing sent from compromised enterprise accounts and characterized it at scale; the multi-hop cascade with a per-contact infection probability is our formalization of the compounding they observed, in which newly compromised recipients become the next senders. Every single message in it is locally plausible: the sender is a genuine contact, the address is real, and the content can be clean.

On capabilities: having mailbox access, the attacker knows the victim's rhythm and can mimic it; the attacker can also *pace* the sends—K carriers, one send per time bucket—so that no sending burst ever appears (the *stealthy* attacker, who defeats volumetric detection by construction); and the attacker can restrict the attack to a single recipient with no propagation at all (the *surgical* attack). Out of scope is an adaptive adversary with full knowledge of the graph and training poisoning, and external impersonation from outside the graph, which requires knowledge beyond G and is treated in a separate study. We treat the signal as a cost increase for the attacker; no detection is final.

3.3. The cascade invariant

Lateral phishing is a propagation process, and propagation has two sides. On the *sending* side a compromise shows up as a surge in one account's volume, or as an unusual path to a rare target; this is what practical defenses read, and it is what a patient attacker controls. On the *receiving* side the cascade leaves a signature that no single message reveals and that the attacker cannot pace away: within the wave's window many of v's neighbors receive mail, and the sender u of the message to v was itself hit just before. This receiving-side wave is the invariant. A learned temporal model with node memory registers it by scoring an event using the state from *before* its bucket, so that it can only use the past (made precise in Sec. 4); a static model of the same topology, which sees who is connected to whom but not in

what order, cannot. The invariant is testable by ablation: shuffling the time order of events destroys the order it relies on (together with within-bucket co-occurrence, Sec. 4.3), so the drop in performance under a time shuffle bounds how much of the signal is dynamics rather than topology.

3.4. Definition of detection effectiveness

Every result in the Case Study follows a standard that is detector-independent and operational; the Methodology (Sec. 4) is the protocol that operationalizes it.

A high benchmark accuracy alone does not attest to detecting lateral phishing. A method works operationally for the targeted tail only when its advantage is temporal, vanishing under a control that destroys the temporal order, and transferable, so that the qualitative hierarchy of methods—which class wins, and where it breaks down—carries over to other topologies. Effectiveness is judged by sensitivity at a low false-positive rate with explicit base-rate accounting, rather than by headline AUC. The leak-aware protocol of Sec. 4 implements this standard.

4. Methodology

The procedure turns the cascade invariant into detectors, guards against inflated results, and checks the metrics against the definition of effectiveness (Sec. 3.4). Concrete values—population, time buckets, cascade parameters, hyperparameters—are stated once, in the Case Study (Sec. 5).

4.1. Overview of the verification procedure

The procedure has four steps that mirror the model. First, instantiate the communication graph G (Def. 1) on a population, deriving the contacts E and the temporal rhythm τ. Then build detectors of increasing temporal awareness, as standard learning instruments over graph-position features, and two strong practical baselines that read the sending side. Evaluation follows under the leak-aware protocol below, so that any advantage due to leakage or capacity is destroyed by a control; the last step checks transfer to real topologies.

4.2. Leak-aware evaluation protocol

Graph detectors are easy to inflate, and the protocol below uses four safeguards against that.

A matched design makes legitimate traffic and attack edges share the same distribution of endpoints and degrees, meaning they differ only by the temporal pattern and the degree/identity confounder is removed (Arp et al., 2022). A time-shuffle control permutes the temporal order of events, which removes the advantage if it comes from dynamics and leaves it intact if it is an artifact of topology or identity (Pendlebury et al., 2019); an inductive split by organization checks that nothing is memorized about the accounts seen in training, and an audit of noisy training labels checks that the learned detector does not depend on clean labels. Operational metrics report sensitivity at a low FPR, with explicit base-rate arithmetic, rather than relying on headline AUC alone. A *predictivity probe* then asks whether what was established on one topology carries over to another (real Enron, SNAP graphs). The probe checks two properties: that the *qualitative hierarchy* of detectors—which class wins, and in which attack regime it breaks down—is reproduced on each real graph, and that the headline contrast (receiving-side signal vs. volume) keeps its direction there; with the few seeds available per real graph this is a directional check, not a significance test. We deliberately do not reduce the probe to a single rank-correlation coefficient: over a handful of detectors such a coefficient is underpowered, and the transferable claim is the regime-level contrast, not a full ranking. Together these give the working definition of effectiveness of Sec. 3.4: a method works when its advantage meets the standard defined there.

4.3. Detectors and causal controls

The design principle is uniform: features encode graph position and timing, never identity. This makes every detector inductive and applicable to accounts unseen in training.

The invariant operates on the contacts graph $G = (V, E)$ with time divided into T buckets. An attack is a cascade where a patient-zero s_0 sends malicious mail to contacts; each recipient becomes a carrier with probability p_{inf} and propagates to depth H (Fig. 2). A single event $u \to v$ is locally indistinguishable from legitimate mail; the signal is the cascade context, since within the wave's window many of v's neighbors receive mail and u was hit just before. Four detectors of increasing temporal awareness are compared: a 1-hop tabular model (a lower bound), a hand-crafted cascade context (1-hop plus burst, freshness, and wave density), a static GNN (topology, no time), and a temporal GNN with node memory.

The two equations below differ in one respect: whether the model may look forward in time. The static score summarizes a node by its neighbors in the whole aggregated graph, seeing who is connected to whom but not in what order. The temporal score keeps a running memory updated bucket by bucket and read one bucket before the event it scores, so its memory can only use the past. reading is what lets the receiving-side wave become a signal, and it is what a time-shuffle destroys.

The static GNN builds embeddings from the aggregated graph with a normalized adjacency $\hat{A}$ and features X,

$$Z = \hat{A}\,\sigma\big(\hat{A}\,X\,W_1\big)\,W_2, \qquad \text{score}_{\text{stat}}(s,v) = g\big([\,Z_s,\,Z_v,\,Z_s \odot Z_v,\,x_{sv}\,]\big), \tag{1}$$

whereas the temporal GNN maintains a memory $m_v^{(b)}$ and scores an event of bucket b using the state from before its update, which preserves causality and avoids leakage,

$$\text{score}_{\text{temp}}(s,v,b) = g\big([\,m_s^{(b-1)},\,m_v^{(b-1)},\,m_s^{(b-1)} \odot m_v^{(b-1)},\,x_{sv}\,]\big), \tag{2}$$

$$m_v^{(b)} = \text{GRU}\Big(\tfrac{1}{d_v^{(b)}} \sum_{u:\,(u\to v)\in b} \sigma\big(W_m\,m_u^{(b-1)}\big),\; m_v^{(b-1)}\Big), \tag{3}$$

where $d_v^{(b)}$ is the in-degree of node v within bucket b (a normalizer for the mean-pooled message).

The shuffle control is a temporal ablation. Since $\text{score}_{\text{stat}}$ is permutation-invariant in time while $\text{score}_{\text{temp}}$ is not, the drop in AUC_{temp} after time shuffling indicates how much the model relies on temporal order. The ablation is not perfectly selective: shuffling also breaks the co-occurrence of events within a bucket, so the drop is an upper bound on the contribution of order alone (consistent with the shuffled temporal model falling slightly below the static GNN, Tab. 3). We use "causal" in this ablation sense throughout, not in the sense of causal identification.

Beyond the GNN we implement two strong practical methods, both of which read the sending side.

- A volumetric baseline inspired by COMPA (Egele et al., 2013; Stringhini and Thonnard, 2015) scores an event by the sender's deviation from its own volume profile—how unusual the recipient, the time bucket, and the sender's overall activity are (three per-event features, Supplementary Sec. S6)—with the same gradient-boosting learner as the other tabular detectors,
- and a path-based baseline that transfers the causal-path idea of Hopper (Ho et al., 2021), a detector of lateral movement in login graphs, to the email graph: it looks for a causal precursor, momentum, and a rare target.

We implement their structural-temporal core rather than the full systems, which is why we label them "volumetric" and "path-based"; the exact feature set of every detector is listed in Supplementary Sec. S6, together with what the full systems add on top. Hyperparameters of all detectors are fixed uniformly, without intensive tuning, so that no detector enjoys a tuning advantage; the concrete settings are given in Supplementary Tab. S1.

4.4. Event model and data split

An event is a pair (sender s, victim v) with a bucket b, labeled legitimate or attack, with two-sided noise so that the classes are not perfectly separable. Legitimate events are messages between known contacts in rhythm, with a fraction arriving off-rhythm (an irreducible source of false positives). Attacks are the events of a cascade seeded at a compromised account, a fraction of which mimic the sender's rhythm. We use two split regimes, victim-wise (disjoint victim sets) and organization-wise (test organizations disjoint from training ones, an inductive validation). Headline claims are hardened over many seeds; validations on real graphs use fewer seeds, since variance is lower on a fixed structure, with a Wilcoxon test where significance matters. Seed counts for each experiment are given in the respective table or figure caption.

4.5. Metrics, base rate, and threats to validity

The headline metric is sensitivity at a fixed low FPR, the operational working point, $\text{sensitivity@FPR} = \max\{\text{TPR}(\theta) : \text{FPR}(\theta) \le \alpha\}$ (where $\alpha = 0.01$ for our primary analysis); AUC is reported alongside it. Real systems operate at a far stricter FPR (<4 FP/million, (Ho et al., 2019)), so the FPR reported here (an FPR of 10^{-2} against $4{\cdot}10^{-6}$) is a liberal operating point rather than a deployment threshold; at a realistic prevalence, precision follows from Bayes' theorem, which we make explicit in the Case Study (Sec. 5.8). To isolate the signal we use the temporal-order shuffle as the causal control: if the signal is truly dynamic, the control must destroy the advantage.

Threats to validity. The internal threats are label leakage, which we counter by separating features from the hidden infection state and letting the shuffle control isolate the mechanism, and dependence on the cascade parameters, which

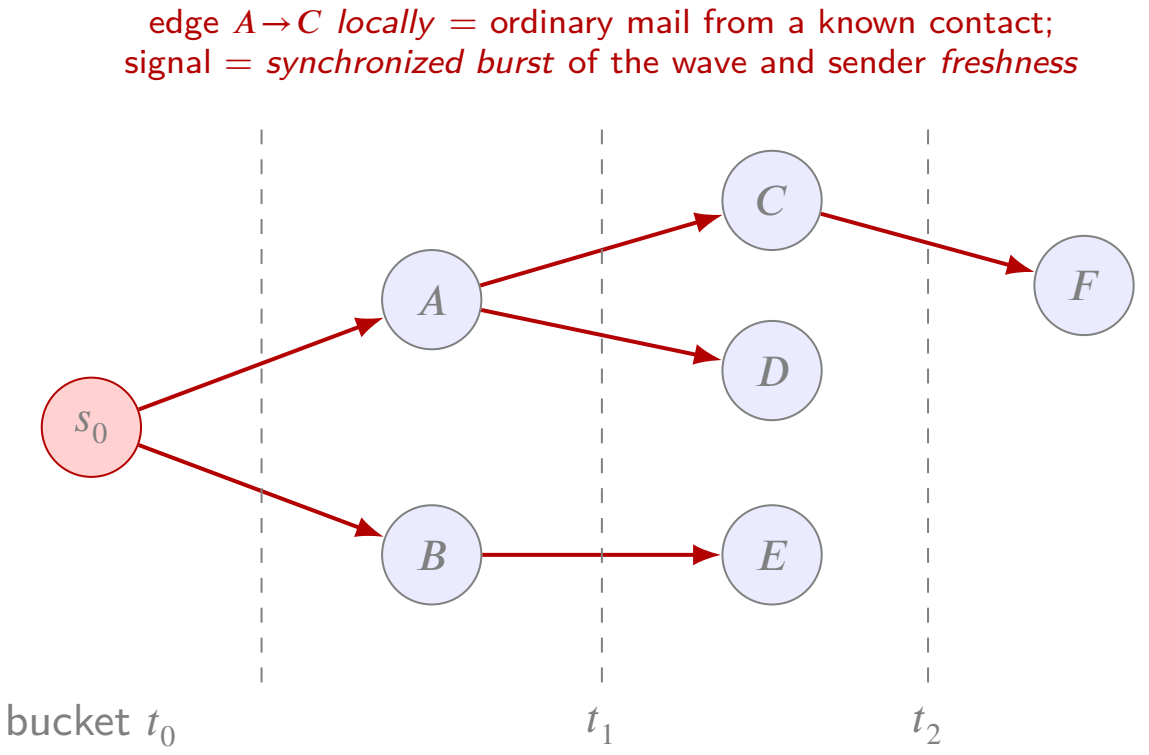


Figure 2: Lateral phishing as a temporal cascade: a carrier (s_0) infects contacts, and those in turn infect their own, so the wave propagates across the graph. Detection requires *multi-hop, temporal* propagation context.

we counter by sweeping the infection probability and depth (Supplementary Tab. S2). The external threat is that the maliciousness is synthetic, so we validate the mechanism on real Enron and two SNAP graphs under controlled injections; the synthetic data lets us control the cascade at the cost of absolute effects. The construct threat is addressed by preferring sensitivity at low FPR to headline AUC, in line with (Arp et al., 2022; Pendlebury et al., 2019).

5. Case Study and Results

The *case study* defines the organizational population, the communication graph with its rhythm, and the cascade parameters that instantiate G, providing the concrete values for the symbols in Sec. 3.

5.1. Case study: the organization and what is tested on it

The case study is a fully specified organizational ecosystem (Fig. 3): 19 firms from distinct sectors (a bank, a hospital group, a software house, a law firm, a logistics company, an insurer, a public office, …), each a small office of ∼8 accounts with one managing director, one senior manager, and five to six specialists and analysts (19/19/57/55 accounts in the four seniority levels). Everyone in a firm corresponds with everyone else in it, and the firms are tied into a ring of business partnerships (director to director, plus one specialist counterpart per partnership), which gives N=150 accounts and 556 contact edges (518 inside firms, 38 between partner firms). The population is synthetic, but it is generated *graph-first*: the organization graph is designed deterministically and each persona is then generated *in its node*, so that a persona's supervisor, coworkers, and external contacts are *real other personas* with real corporate addresses, and the graph closes internally. The size N=150 is of the order of the core user set of the Enron corpus (Klimt and Yang, 2004); the Enron contacts graph used for validation (Sec. 5.7) is larger (1990 accounts), so the real-graph replication also tests the mechanism at a larger scale.

We divide the week into T=28 buckets (7 days × 4 six-hour blocks); an account's rhythm τ is the set of its active buckets (6 per persona synthetically; on Enron derived from the `Date` headers). Realistic noise: 15% of legitimate mail

arrives off-rhythm and 25% of attacks mimic the rhythm. For the cascade (Sec. 4.3) the per-contact infection probability is p_{inf}=0.6 and the maximum depth is H=4. Detector hyperparameters are fixed uniformly (Supplementary Tab. S1).

What the case study tests One kind of attack is injected into this graph, in three regimes (Fig. 3). A *compromised internal account* s_0 mails its own contacts off-rhythm; each recipient becomes a carrier with probability p_{inf}, so the attack spreads as a cascade that crosses into the partner firm through the business-partnership edge. The sender is a genuine contact consistent with every static relation, so only the timing and the receiving-side wave give it away, and this is what T1 must catch. Beyond the default cascade we probe three *extreme* regimes, each chosen to stress a specific claim rather than to represent typical traffic. *(i) Naive blast*: one carrier infects all contacts at once, the easy case that *volume* detection should win, included as a sanity ceiling. *(ii) Stealthy spread* (K carriers, one send per interval, down to K=1): the burst is smeared out, so this is the case that *breaks* volume detection and isolates the receiving-side signal. *(iii) Single-recipient surgical attack* (p_{inf}=0, fan-out 1): no propagation at all, the *blind spot* that no cascade detector can see, included to mark the lower boundary of the threat model (T2). The stealthy-attacker and baseline contrasts are averaged over 20 random seeds on synthetic data and the detector hierarchy over 5; real-graph validations use 8 (Enron) and 3 (SNAP) seeds. Seed counts are stated in every caption.

5.2. Results overview

Table 2 maps the two research questions of Sec. 1 to the evidence; the subsections follow that order. Results are reported on a victim or organization split, as AUC and, where the operating point matters, sensitivity@FPR1%; the time-shuffle control is applied to the detector hierarchy on the case-study graph and on Enron. Seed counts are stated in each table or figure caption.

	Sub-thesis	Main evidence	Verdict
RQ1	the receiving-side cascade signal detects a compromise and degrades less than volume under a stealthy attacker (T1)	Tabs. 3–5(a); real graphs: Tab. 6; Secs. 5.3–5.5, 5.7	degrades less than volume under stealth; vanishes under time shuffle; replicates in direction on three real graphs
RQ2	the signal needs fan-out ≥ 2, degrades gracefully, and is a triage instrument at a real base rate (T2)	Tab. 5(b); Supplementary Tabs. S3–S4; Tab. 7; Secs. 5.5, 5.6, 5.8	fan-out ≥ 2 needed; graceful under noise and scale; triage, not autonomous defense

Table 2
Map from research questions to evidence. Each verdict is established in the section listed.

5.3. The cascade detectors

A compromised account passes every static relation, so static graph position alone carries little operational signal (the static GNN reaches AUC 0.77 but only 0.063 sensitivity at FPR 1%). The signal must therefore lie in the dynamics. Table 3 tests T1 on the default cascade of Fig. 3 and shows a clear hierarchy among detectors (bar chart in Supplementary Fig. S1): local 1-hop features are essentially useless (AUC 0.70, sensitivity@FPR1% ≈ 0), while a hand-crafted multi-hop context reaches 0.87. A static GNN captures the topology but misses the timing (0.77), leaving the temporal GNN in the lead (AUC 0.90, sensitivity@FPR1% 0.139). This advantage is temporal in the ablation sense. A simple time permutation drops the temporal GNN back to the static level ($0.90 \rightarrow 0.72$, sensitivity $0.139 \rightarrow 0.027$). Architecture choice matters less than the paradigm; TGN-lite and TGAT-lite outperform the hand-crafted context in all 5 seeds, and the library TGN (Rossi et al., 2020) matches them on the operational metric.

5.4. The stealthy attacker

Table 4 is the headline test of T1: the stealthy attacker breaks volume, but not dynamics. Against an attacker who evades detection by spreading its sends over time (K carriers, one per interval), the volume detector breaks down (AUC $0.72 \rightarrow 0.44$ at K=1, below random) because the sending burst disappears, while the temporal GNN degrades less and stays above chance (AUC 0.60, sensitivity@FPR1% 0.039 vs 0.017) because it picks up the receiving side of the cascade. At K=1 the temporal signal is weak in absolute terms; the claim is the relative one, that it does not

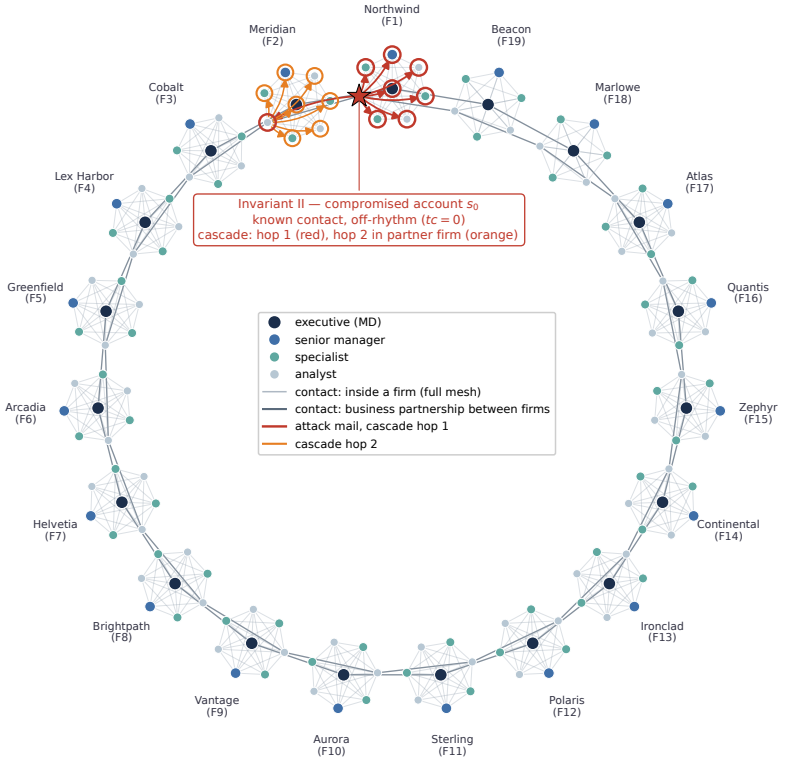


Figure 3: The case-study organization, drawn from the population data of the reproducibility package: 19 firms on a ring of business partnerships, 150 accounts colored by seniority, and the real contacts layer (556 edges). Overlaid is the attack the detectors must catch: a compromised account s_0 (star) whose off-rhythm mail cascades through its own firm (hop 1, red) and into the partner firm through the business-partnership edge (hop 2, orange). Every message in the cascade comes from a genuine contact; only the timing and the receiving-side wave reveal it.

Detector	AUC	sensitivity@FPR1%
1-hop (tabular)	0.70	0.006
Static GNN	0.77	0.063
Hand-crafted context (tab.)	0.87	0.031
Temporal GNN	**0.90**	**0.139**
Temporal (time shuffled)	0.72	0.027

Table 3
Cascade detectors on the case-study graph (victim split, 5 seeds): only the temporal model with node memory reaches operational sensitivity (0.139 at FPR 1%), and shuffling the time order removes the advantage ($\rightarrow 0.027$), so the signal depends on temporal order.

	AUC		sensitivity@FPR1%	
Level	vol.	temp.	vol.	temp.
K=1 (extremely stealthy)	0.44	**0.60**	0.017	**0.039**
K=2	0.56	**0.75**	0.021	**0.098**
K=3	0.58	**0.77**	0.025	**0.043**
K=5	0.68	**0.78**	0.044	**0.061**
blast	0.72	**0.85**	0.047	**0.114**

Table 4
Stealthy attacker on the case-study graph (K carriers spread over time; 20 seeds): as $K \to 1$ the volume detector falls below random (0.44) while the receiving-side temporal detector degrades less and stays above chance (0.60), the headline operational result behind T1.

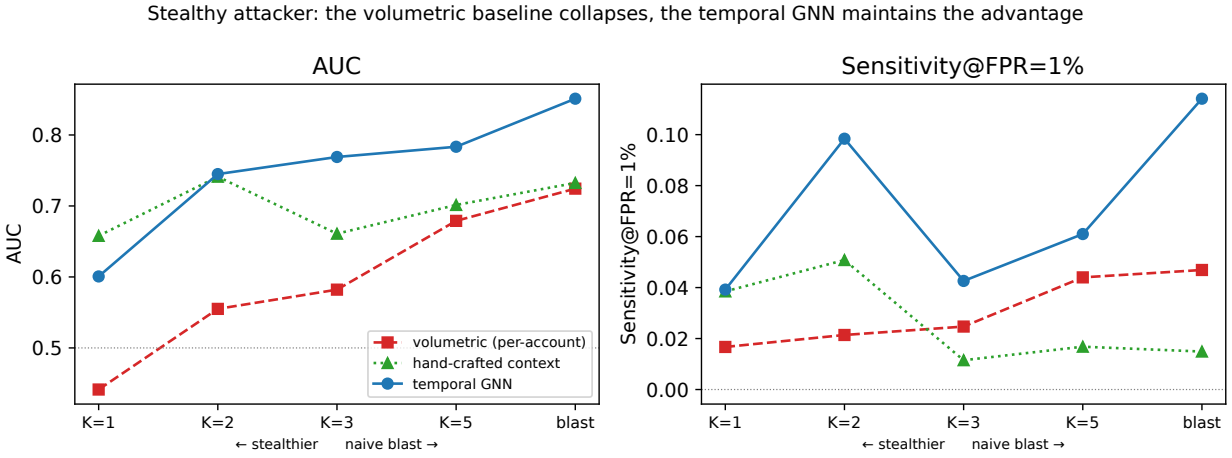


Figure 4: The stealthier the attack (smaller K), the more strongly the volume detector breaks down; the temporal GNN degrades less thanks to the cascade's receiving-side signal.

collapse. The temporal sensitivity column is not monotone in K (a dip at K=3: 0.098 → 0.043 → 0.061) while the corresponding AUC rises monotonically (0.75 → 0.77 → 0.78); we attribute the dip to seed-level variability of the low-FPR operating point, which depends on a tail quantile of the score distribution, rather than to a change in mechanism.

Figure 4 plots the same breakdown across K: the stealthier the attack, the further the volume detector falls, while the receiving-side signal keeps its margin.

5.5. Baselines and the boundary of the threat model

Table 5 places this result against the two strong practical baselines and marks the boundary of the threat model. This table comes from the second experiment harness (Supplementary Sec. S6), so its K=1 values differ slightly from Tab. 4. In the stealthy regime (block a) the hand-crafted context leads under extreme stealth (K=1: 0.76, ahead of the path-based 0.68 and the temporal GNN 0.65) but falls behind as soon as the cascade reaches further; the path-based detector degrades with reach (0.68→0.59); and the temporal GNN is the only detector that stays within a narrow band (0.65–0.82) across all levels, leading from K=2 on. In the surgical regime (block b, no propagation at all, p_{inf}=0) a single-recipient attack is undetectable by every detector (AUC ∼ 0.46): the signal requires fan-out ≥ 2, and this is the measured lower boundary of what the detectors can see (T2). Block (b) also shows that propagation itself is not required: with p_{inf}=0 and fan-out ≥ 2 the attack is caught by the volume detector (0.84–0.98) and by the temporal GNN (0.77–0.96), because several recipients in one neighborhood hit at once already form a synchronized sending burst and a receiving-side wave. What the signal needs is fan-out, not a cascade; the cascade matters because it is what lets a stealthy attacker reach many victims *without* such a burst.

Regime / level	vol.	path	manual	temp.
(a) Stealthy cascade: K carriers, one send per bucket, p_{inf}=0.6 (reach in parentheses)				
K=1 (11%)	0.48	0.68	**0.76**	0.65
K=2 (27%)	0.67	0.66	0.65	**0.76**
K=3 (45%)	0.72	0.61	0.61	**0.78**
K=5 (63%)	0.78	0.58	0.65	**0.80**
blast (77%)	**0.82**	0.59	0.71	**0.82**
(b) Surgical attack without propagation: p_{inf}=0, by fan-out				
fan-out 1 (single recipient)	0.48	0.47	0.45	0.45
fan-out 2	0.84	0.51	0.47	0.77
fan-out 3	0.94	0.50	0.45	0.91
fan-out 5	**0.98**	0.50	0.50	**0.96**

Table 5
Baselines and the boundary of the threat model (AUC, 20 seeds; path-based baseline in the spirit of Hopper (Ho et al., 2021)). (a) Under a stealthy cascade the hand-crafted context leads only at K=1, the path-based detector degrades with reach, and the temporal GNN is the only detector without a breakdown regime. (b) With no propagation, a single-recipient attack is invisible to every detector ($\sim$0.46); the signal needs fan-out ≥ 2. The two blocks are not comparable at "1": in (a) K=1 still propagates, in (b) fan-out 1 is a surgical attack with no cascade at all.

5.6. Stability and inductive generalization

Two checks bound the reading of T1. The cascade model sweep (Supplementary Tab. S2) shows the hierarchy holding across the whole range $p_{\text{inf}} \in [0.05, 0.9]$ and depth; the receiving-side signal does not vanish at a realistically low p_{inf} (temporal GNN 0.91–0.96). Under inductive validation across disjoint organizations (Supplementary Tab. S3 and Fig. S2), the temporal GNN does *not* lead on AUC—the hand-crafted context ranks slightly better at every scale (0.86–0.88 vs 0.80–0.84)—but it keeps the operational advantage at FPR 1% on unseen companies (4.4× at 19 companies, 1.6× at 30, 1.4× at 200), an advantage that shrinks with scale. The temporal GNN is thus a better operational detector than a ranker, at least at the scales we test.

Cascade dynamics thus overcome the blindness of static relations to a compromise and, unlike the volume detector, do not collapse under a stealthy attacker; the advantage depends on temporal order and keeps its operational edge on unseen organizations. The next question is whether the mechanism is a property of the generator or of communication graphs.

5.7. Validation on real communication graphs

Real graphs (Enron, two SNAP graphs) are used to validate the mechanism where the structure and rhythms are real. The qualitative hierarchy of methods established on one topology must carry over to another, in line with the definition of effectiveness (Sec. 3.4). The attack labels are controlled injections under a matched design, so legitimate traffic and attack are edges with the same distribution of endpoints and degrees, distinguished only by their temporal pattern.

Table 6 reports both replications. On the real Enron contacts graph (1990 accounts, 8 seeds, leak-free; block a) the cascade experiment reproduces the hierarchy from the case-study graph (bar chart in Supplementary Fig. S4): 1-hop 0.65, hand-crafted context 0.77, temporal GNN 0.85 (beating the hand-crafted context in 8/8 seeds), with time shuffling leveling it to the hand-crafted result (0.77). The advantage depends on temporal order on the real topology as well. On `email-Eu-core` (Paranjape, Benson and Leskovec, 2017) and `CollegeMsg` (Panzarasa, Opsahl and Carley, 2009) ((Leskovec and Krevl, 2014); block b, bar chart in Supplementary Fig. S3) the regime transition replicates: against the naive blast the volume detector dominates (0.97), but against a stealthy attacker it drops (0.70/0.66) while the temporal GNN stays higher (0.88/0.85). The predictivity probe is therefore positive in the regime-level sense of Sec. 4.2: on each of the three real graphs the qualitative hierarchy is reproduced—the volume detector wins the naive blast and drops under the stealthy attacker, while the receiving-side temporal signal stays higher—and the headline contrast keeps its direction beyond a single corpus. With 3–8 seeds per graph a per-graph Wilcoxon test cannot reach conventional significance (the minimum two-sided p is 0.25 for n=3), so we report the real-graph replications as directional confirmations, not as significance tests. We do not claim that the full detector ranking transfers; the transferable claim is the regime-level contrast.

Graph (regime)	Detector	AUC	sensitivity@FPR1%
(a) Enron contacts graph, 1990 *accounts, default cascade, matched design,* 8 *seeds*			
Enron	1-hop (tabular)	0.65	0.022
	Hand-crafted context (tab.)	0.77	0.042
	Temporal GNN	**0.85**	**0.072**
	Temporal (time shuffled)	0.77	0.049
(b) SNAP graphs, naive blast vs stealthy attacker, 3 *seeds*			
`email-Eu-core` (blast)	volumetric	**0.97**	**0.29**
	temporal GNN	0.70	0.06
`email-Eu-core` (stealthy)	volumetric	0.70	0.00
	temporal GNN	**0.88**	**0.08**
`CollegeMsg` (blast)	volumetric	**0.97**	**0.35**
	temporal GNN	0.70	0.04
`CollegeMsg` (stealthy)	volumetric	0.66	0.02
	temporal GNN	**0.85**	**0.12**

Table 6
Replication on three real communication graphs. (a) On Enron the case-study hierarchy is reproduced (1-hop < hand-crafted context < temporal GNN) and the time shuffle levels the temporal detector to the hand-crafted result, so the advantage depends on temporal order on a real topology. (b) On two SNAP graphs the regime transition replicates in direction: the volume detector wins the naive blast and drops under the stealthy attacker, while the temporal detector stays higher.

5.8. Rigor: what it means for a detector to work

The results follow the definition of effectiveness (Sec. 3.4) and the operational limits are marked, so the headline numbers read as a lower bound rather than a deployment claim.

Variance and significance. The stealthy-attacker, baseline, and label-noise contrasts are averaged over 20 seeds on synthetic data; the detector hierarchy (Tab. 3) uses 5, the cascade sweep (Supplementary Tab. S2) 8, the inductive validation (Supplementary Tab. S3) 5 or 3, the sensitivity–FPR curve (Supplementary Fig. S5) 10, and the real-graph replications (Tab. 6) 8 (Enron) and 3 (SNAP); per-seed values for every table are available in the reproducibility package (`code/results/*.csv`). Strengthening the main contrast on 20 seeds at the stealthy point with a paired Wilcoxon test and Cliff's δ, the receiving-side signal beats the volume detector significantly and with a large effect (temporal GNN +0.081 AUC, $p < 0.001$, δ=0.88), and the learned GNN beats the hand-crafted context (+0.064, $p < 0.001$, δ=0.78), whereas the hand-crafted context alone does not significantly beat volume (+0.017, p=0.28, δ=0.28). Under a stealthy attack, then, it is the receiving-side signal read by a temporal model that surpasses volume detection. For the whole curve, instead of a single threshold we report the sensitivity–FPR curve (Supplementary Fig. S5): at a realistically low FPR (0.1%) all methods are weak.

The volumetric collapse is not a tuning artifact. The volumetric baseline has no window or threshold to tune: its three features are counts over the observed stream (recipient novelty, time novelty, sender activity; Supplementary Sec. S6) fed to the same learner as every other tabular detector. Its collapse under the stealthy attacker is therefore a property of the attack model—one send per bucket leaves no per-bucket surge for any volume statistic to see—rather than of a baseline configuration.

Label noise. Flipping an increasing fraction of training labels (Supplementary Tab. S4) shows that the learned GNN degrades fastest (temporal 0.82 → 0.70 at 20% noise, volume only 0.79 → 0.75). Under realistic label noise the advantage of the learned model shrinks—another boundary of T2.

Base rate. Sensitivity at a given FPR is independent of prevalence, but precision drops when the attack is rare. From Bayes' theorem $\mathrm{prec}(\pi) = r\pi/(r\pi + \alpha(1-\pi))$ (4): at the operating point of sensitivity r=0.14 at FPR α=1% and a real prevalence of $1:10^4$, each detected attack comes with ∼ 700 false alarms (Tab. 7); in terms of false-positive rate, our operating point (10^{-2}) is about three orders of magnitude (∼2500×) above the threshold of Ho et al. (2019) (< 4/million, i.e. $4 \cdot 10^{-6}$). The consequence is that at a real prevalence our detectors, and any detector with a similar ROC curve, are triage and ranking tools, so the contribution lies in the signal, the mechanism, and the methodology.

$$\mathrm{prec}(\pi) \;=\; \frac{r\,\pi}{r\,\pi + \alpha\,(1-\pi)}, \tag{4}$$

Attack frequency	Precision	FP per detected attack
1:3 (evaluation)	0.82	0.21
1:100	0.12	7
1:1000	0.014	71
1:10 000	0.001	714
$1:10^6$	<0.001	71 000

Table 7
Base-rate arithmetic for the temporal GNN operating point (sensitivity 0.14, FPR1%): at a realistic prevalence of $1:10^4$ each detected attack comes with $\sim$700 false alarms, three orders of magnitude above the deployment threshold in FPR terms, which is why the detectors are triage instruments. "FP per detected attack" is $\alpha(1-\pi)/(r\pi)$, where r is sensitivity, α is FPR, and π is prevalence; "$1:n$" is the ratio of attack to legitimate events, i.e. $\pi = 1/(n+1)$.

where r is sensitivity, α is FPR, and π is the attack prevalence (base rate).
An operational method meets the standard of Sec. 3.4: its advantage vanishes under the time-shuffle control, transfers across topologies by the predictivity probe, and is measured at low FPR with explicit prevalence arithmetic. By this standard, 98% on a mass benchmark says nothing about lateral phishing. What counts is sensitivity to the targeted tail, with a stated floor (the surgical attack) and an explicit threshold still orders of magnitude away. The next section interprets this gap.

6. Discussion

The cascade invariant addresses the failure mode that sending-side defenses cannot cover, and the rigor analysis marks where the signal stops being operationally useful. We focus here on the mechanism's implications and its limits.

6.1. Interpretation: why the receiving side degrades less

A volumetric detector in the spirit of COMPA (Stringhini and Thonnard, 2015) assumes that a compromise shows up as a surge; a path-based detector in the spirit of Hopper (Ho et al., 2021) assumes an unusual route to a rare target. Both read what the attacker controls. When the attacker deliberately spreads the sends over time, the volumetric signal vanishes and its AUC drops below the random baseline, and the path-based signal degrades as the cascade reaches further. Cascade dynamics instead respond to the recipient side, the wave-like signature among the neighbors, which the sender cannot hide without giving up fan-out altogether—and a single recipient is exactly the surgical regime, which we mark as the blind spot. Pacing the sends weakens this signal (AUC 0.60 at K=1) but much less than it weakens volume. This agrees with Ho et al. (Ho et al., 2019) that lateral phishing needs a signal beyond the content of a single message; we differ in locating that signal in the dynamics of the communication graph rather than in headers or relays. The time-shuffle control supports the temporal reading: shuffling removes the temporal order (and, as a side effect, within-bucket co-occurrence), and with it the advantage over the static model.

6.2. Practical implications

For a SOC, the result says what to monitor and where the monitor fails. The receiving-side wave is a property of the organization's own communication graph, computable from headers alone, so it fits an in-house triage pipeline that does not inspect content. The blind spot is equally concrete: a single-recipient transfer request from a compromised account is invisible to every detector studied here, so out-of-band verification of transfers remains the control for that case, and the cascade detector should be paired with it rather than replace it. Two further boundaries shape deployment. The learned model is the most sensitive to noisy training labels, so retraining on analyst-confirmed labels matters more for it than for the volumetric baseline; and at a realistic base rate every detected attack comes with hundreds of false alarms, so the detectors are ranking instruments for analysts, not autonomous blockers. Combining header-only scoring on the graph with content and process controls is the realistic operating mode.

6.3. Limitations

The limitations define the scope of these claims. First, the maliciousness is synthetic. No public corpus links real accounts with labeled compromises and their propagation, so we generate cascades on real structure (Enron, SNAP) or

on a synthetic population. We validate the mechanism (a paced cascade separates from legitimate traffic by its receiving-side dynamics), not the detection of real intrusions; the real-graph replications establish the receiving-side signal on real topologies and rhythms, but the injected cascades follow our threat model. Second, the cascade parameters (p_{inf}, depth, fan-out, the stealthy attacker's pacing) are ours; the sweeps in the Supplement show the hierarchy is stable across them, but an attacker who sends to a single recipient (fan-out 1) is outside the signal by construction. Third, the scale is limited (N=150 accounts in the case study; real graphs up to about 2k nodes), making the comparison with heavy temporal architectures a sanity check rather than a full benchmark. The case-study graph is also denser than typical corporate mail: every account corresponds with everyone in its firm and only 7% of the contact edges cross firms, so the synthetic cascades meet a compact, well-connected neighborhood. The replications on Enron and the SNAP graphs, whose density and rhythms are real, are what carries the mechanism beyond that setting; the SNAP replication rests on 3 seeds, so we read it as a regime-level confirmation rather than as a precise effect size. Finally, the operational threshold remains a gap. Even the best operating point (sensitivity@FPR1%) is orders of magnitude from the deployment threshold on real mail (Ho et al. (Ho et al., 2019): < 4 FP/M); we report that gap as the open requirement, not as a solved one.

6.4. Future work directions

The most important next step is validation on a corpus with labeled, real compromises, turning the proof of mechanism into a measurement of detectability. The threat model should then be stressed: an attacker that *learns* the communication graph and tunes both the pacing and the propagation pattern to stay below the receiving-side signal, together with population drift over time (TESSERACT (Pendlebury et al., 2019)). On the modeling side, richer relational context—the organization's hierarchy, competencies, and public footprint as additional layers over the same accounts—is the natural complement for the external impersonation mode, which we study separately. Finally, the receiving-side score is a natural input to a SOC's triage queue, provided an evaluation ties it to a real reduction in analyst load at a fixed alert budget.

7. Conclusions

Modern phishing detection works in aggregate, yet a residual fraction—spear phishing and BEC—remains the most costly and largely evades content filters, and lateral phishing from a compromised account is its hardest case, because every static relation the sender exhibits is genuine. The gap is temporal. By modeling the organization's communication graph with its rhythm, the violation becomes measurable in the dynamics.

We answer the two research questions in turn.

RQ1 (signal, T1): A compromised account consistent with every static relation is detected from the receiving-side wave of its cascade. Unlike volume-based detection, the temporal detector degrades less and stays above chance against a stealthy attacker who spreads the sends over time (Section 5.4); the advantage vanishes under a time-shuffle control and transfers in direction to three real communication graphs (Section 5.7).

RQ2 (limits, T2): The signal needs fan-out: a single-recipient attack is invisible to every detector (Section 5.5). The advantage degrades gracefully with scale and shrinks under label noise, and at a realistic base rate the detectors act as triage instruments, with effectiveness defined operationally through low-FPR sensitivity under ablation controls and explicit prevalence arithmetic (Section 5.8).

As its contributions, the paper offers a formalization of lateral phishing as a temporal violation of the organizational communication graph, with a cascade threat model that includes the stealthy attacker; the receiving-side cascade signal as a detection invariant, with a hierarchy of detectors, a time-shuffle control, and validation on three real communication graphs; and a leak-aware evaluation methodology with an operational definition of detection effectiveness for the targeted tail.

Among the limitations, the maliciousness is synthetic, so we validate the mechanism rather than the detection of real intrusions; the cascade parameters are ours; and both scale and the operational threshold remain open. Section 6 gives the details.

The results turn lateral phishing into a quantity that can be tracked rather than merely flagged. Under the default cascade the receiving-side signal reaches AUC 0.90; under a stealthy attacker it degrades to 0.60–0.78 but stays above chance while volume detection collapses to 0.44, below the random baseline; and the same regime transition appears in direction on Enron, `email-Eu-core`, and `CollegeMsg`. The defense this points toward asks not whether a message looks malicious, but whether the organization's communication graph is behaving the way it usually does. Turning that

question into an operational filter in the SOC pipeline, at the precision real deployment demands, remains an open problem.

CRediT authorship contribution statement

Kamil Warpechowski: Conceptualization, Methodology, Software, Investigation, Validation, Writing – original draft. **Bogdan Księżopolski:** Supervision, Conceptualization, Writing – review & editing.

Declaration of competing interests

The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Funding

This research did not receive any specific grant from funding agencies in the public, commercial, or not-for-profit sectors.

Data availability

The reproducibility package, including the synthetic population generator, all experiment and analysis code, the generated population of 150 personas, and the computed results from which the tables and figures are produced, is openly archived on Zenodo (DOI: to be inserted upon deposit). The real communication graphs used for validation are public: the Enron email corpus (Klimt and Yang, 2004) and the SNAP datasets `email-Eu-core` and `CollegeMsg` (Leskovec and Krevl, 2014).

Declaration of generative AI and AI-assisted technologies in the manuscript preparation process

During the preparation of this work the authors used Claude (Anthropic) in order to translate the manuscript from Polish into English and to copy-edit the prose. After using this tool, the authors reviewed and edited the content as needed and take full responsibility for the content of the published article.

References

Abdelnabi, S., Krombholz, K., Fritz, M., 2020. VisualPhishNet: Zero-day phishing website detection by visual similarity, in: ACM CCS, pp. 1681–1698. doi:10.1145/3372297.3417233.

Arp, D., Quiring, E., Pendlebury, F., Warnecke, A., Pierazzi, F., Wressnegger, C., Cavallaro, L., Rieck, K., 2022. Dos and don'ts of machine learning in computer security, in: 31st USENIX Security Symposium. doi:10.48550/arXiv.2010.09470.

Atlam, H.F., Oluwatimilehin, O., 2023. Business email compromise phishing detection based on machine learning: A systematic literature review. Electronics 12. doi:10.3390/electronics12010042.

Behrouz, A., Seltzer, M., 2022. Anomaly detection in multiplex dynamic networks: from blockchain security to brain disease prediction. arXiv:2211.08378.

Bethany, M., Galiopoulos, A., Bethany, E., Karkevandi, M.B., Vishwamitra, N., Najafirad, P., 2024. Evaluating large language models' capability to launch fully automated spear phishing campaigns: Validated on human subjects. arXiv:2412.00586.

Bian, T., Xiao, X., Xu, T., Zhao, P., Huang, W., Rong, Y., 2020. Rumor detection on social media with bi-directional graph convolutional networks, in: Proceedings of the AAAI Conference on Artificial Intelligence. doi:10.1609/aaai.v34i01.5393.

Birthriya, S.K., Ahlawat, P., Jain, A.K., 2025. Detection and prevention of spear phishing attacks: A comprehensive survey. Computers & Security 151. doi:10.1016/j.cose.2025.104317.

Bountakas, P., Xenakis, C., 2022. HELPHED: Hybrid ensemble learning PHishing email detection. Journal of Network and Computer Applications 210. doi:10.1016/j.jnca.2022.103545.

Butavicius, M., Taib, R., Han, S.J., 2022. Why people keep falling for phishing scams: The effects of time pressure and deception cues on the detection of phishing emails. Computers & Security 123. doi:10.1016/j.cose.2022.102937.

Cheng, J., Adamic, L., Dow, P.A., Kleinberg, J.M., Leskovec, J., 2014. Can cascades be predicted?, in: Proceedings of the 23rd International Conference on World Wide Web. doi:10.1145/2566486.2567997.

Cidon, A., Gavish, L., Bleier, I., Korshun, N., Schweighauser, M., Tsitkin, A., 2019. High precision detection of business email compromise, in: 28th USENIX Security Symposium.

Ding, K., Li, J., Bhanushali, R., Liu, H., 2019. Deep anomaly detection on attributed networks, in: SIAM SDM. doi:10.1137/1.9781611975673.67.

Dou, Y., Liu, Z., Sun, L., Deng, Y., Peng, H., Yu, P.S., 2020. Enhancing graph neural network-based fraud detectors against camouflaged fraudsters, in: ACM CIKM. doi:10.1145/3340531.3411903.

Duman, S., Kalkan-Cakmakci, K., Egele, M., Robertson, W., Kirda, E., 2016. EmailProfiler: Spearphishing filtering with header and stylometric features of emails, in: IEEE COMPSAC. doi:10.1109/COMPSAC.2016.105.

Egele, M., Stringhini, G., Kruegel, C., Vigna, G., 2013. COMPA: Detecting compromised accounts on social networks, in: Network and Distributed System Security Symposium (NDSS).

Federal Bureau of Investigation, 2024. Internet crime report 2023. URL: https://www.ic3.gov/Media/PDF/AnnualReport/2023_IC3Report.pdf.

Gao, Y., Wang, X., He, X., Liu, Z., Feng, H., Zhang, Y., 2023. Alleviating structural distribution shift in graph anomaly detection, in: ACM WSDM. doi:10.1145/3539597.3570377.

Gascon, H., Ullrich, S., Stritter, B., Rieck, K., 2018. Reading between the lines: Content-agnostic detection of spear-phishing emails, in: RAID. doi:10.1007/978-3-030-00470-5_4.

Guo, B., Wang, S., Yue, T., Sun, Y., Hu, X., 2025. Efficient phishing URL detection using graph-based machine learning and loopy belief propagation. arXiv:2501.06912.

Hamilton, W.L., Ying, R., Leskovec, J., 2017. Inductive representation learning on large graphs, in: NeurIPS. arXiv:1706.02216.

Hao, Y., Cao, X., Fang, Y., Xie, X., Wang, S., 2020. Inductive link prediction for nodes having only attribute information, in: IJCAI. arXiv:2007.08053.

Ho, G., Cidon, A., Gavish, L., Schweighauser, M., Paxson, V., Savage, S., Voelker, G.M., Wagner, D., 2019. Detecting and characterizing lateral phishing at scale, in: 28th USENIX Security Symposium. arXiv:1910.00790.

Ho, G., Dhiman, M., Akhawe, D., Paxson, V., Savage, S., Voelker, G.M., Wagner, D., 2021. Hopper: Modeling and detecting lateral movement, in: 30th USENIX Security Symposium. arXiv:2105.13442.

Klimt, B., Yang, Y., 2004. The Enron corpus: A new dataset for email classification research, in: ECML. doi:10.1007/978-3-540-30115-8_22.

Kumar, S., Zhang, X., Leskovec, J., 2019. Predicting dynamic embedding trajectory in temporal interaction networks, in: ACM KDD. doi:10.1145/3292500.3330895.

Leskovec, J., Krause, A., Guestrin, C., Faloutsos, C., VanBriesen, J., Glance, N., 2007. Cost-effective outbreak detection in networks, in: Proceedings of the 13th ACM SIGKDD International Conference on Knowledge Discovery and Data Mining. doi:10.1145/1281192.1281239.

Leskovec, J., Krevl, A., 2014. SNAP Datasets: Stanford large network dataset collection. http://snap.stanford.edu/data.

Li, S., Gou, G., Liu, C., Hou, C., Li, Z., Xiong, G., 2022a. TTAGN: Temporal transaction aggregation graph network for Ethereum phishing scams detection, in: The Web Conference (WWW). doi:10.1145/3485447.3512226.

Li, S., Xu, G., Xie, R., Zhou, L., Xuan, Q., 2022b. Phishing fraud detection on Ethereum using graph neural network. arXiv:2204.08194.

Li, X., Qi, J., Zhao, Z., Zheng, Y., Cao, L., Dong, J., Yu, G., 2025. UMGAD: Unsupervised multiplex graph anomaly detection, in: IEEE ICDE. arXiv:2411.12556.

Lin, Y., Liu, R., Divakaran, D.M., Dong, J.Y., Ng, G., Jiang, H., Chen, C., Zhang, Y., Lau, Y., Dong, J.S., 2021. Phishpedia: A hybrid deep learning based approach to visually identify phishing webpages, in: 30th USENIX Security Symposium.

Liu, Y., Ao, X., Qin, Z., Chi, J., Feng, J., Yang, H., He, Q., 2021a. Pick and choose: A GNN-based imbalanced learning approach for fraud detection, in: The Web Conference (WWW). doi:10.1145/3442381.3449989.

Liu, Y., Li, Z., Pan, S., Gong, C., Zhou, C., Karypis, G., 2021b. Anomaly detection on attributed networks via contrastive self-supervised learning. IEEE Transactions on Neural Networks and Learning Systems doi:10.1109/TNNLS.2021.3068344.

Liu, Z., Dou, Y., Yu, P.S., Deng, Y., Peng, H., 2020. Alleviating the inconsistency problem of applying graph neural network to fraud detection, in: ACM SIGIR. doi:10.1145/3397271.3401253.

Lo, W.W., Layeghy, S., Sarhan, M., Gallagher, M., Portmann, M., 2021. E-GraphSAGE: A graph neural network based intrusion detection system for IoT. arXiv:2103.16329.

Luo, S., Young, E., Ho, G., Schweighauser, M., Katz-Bassett, E., Cidon, A., 2024. Characterizing the networks sending enterprise phishing emails. arXiv:2412.12403.

Ma, X., Wu, J., Xue, S., Yang, J., Zhou, C., Sheng, Q.Z., Xiong, H., Akoglu, L., 2021. A comprehensive survey on graph anomaly detection with deep learning. IEEE Transactions on Knowledge and Data Engineering 35. doi:10.1109/TKDE.2021.3118815.

Nayebi Kerdabadi, M., Byron, A., Sun, Z., Iranitalab, A., 2025. Spatio-temporal directed graph learning for account takeover fraud detection. arXiv:2509.20339.

Nayeri, Z.M., Rezvani, M., 2026. Alert prediction in computer networks using transformer-based temporal graph neural networks: Identifying the next victim. Journal of Network and Computer Applications 249. doi:10.1016/j.jnca.2026.104455.

Panzarasa, P., Opsahl, T., Carley, K.M., 2009. Patterns and dynamics of users' behavior and interaction: Network analysis of an online community. Journal of the American Society for Information Science and Technology 60, 911–932. doi:10.1002/asi.21015.

Paranjape, A., Benson, A.R., Leskovec, J., 2017. Motifs in temporal networks, in: Proceedings of the Tenth ACM International Conference on Web Search and Data Mining (WSDM). doi:10.1145/3018661.3018731.

Pareja, A., Domeniconi, G., Chen, J., Ma, T., Suzumura, T., Kanezashi, H., Kaler, T., Schardl, T.B., Leiserson, C.E., 2020. EvolveGCN: Evolving graph convolutional networks for dynamic graphs, in: AAAI. arXiv:1902.10191.

Park, C., Kim, D., Han, J., Yu, H., 2020. Unsupervised attributed multiplex network embedding, in: AAAI. arXiv:1911.06750.

Pendlebury, F., Pierazzi, F., Jordaney, R., Kinder, J., Cavallaro, L., 2019. TESSERACT: Eliminating experimental bias in malware classification across space and time, in: 28th USENIX Security Symposium. arXiv:1807.07838.

Pinto, P.C., Thiran, P., Vetterli, M., 2012. Locating the source of diffusion in large-scale networks. Physical Review Letters 109, 068702. doi:10.1103/PhysRevLett.109.068702.

Rayana, S., Akoglu, L., 2015. Collective opinion spam detection: Bridging review networks and metadata, in: ACM KDD. doi:10.1145/2783258.2783370.

Rossi, E., Chamberlain, B., Frasca, F., Eynard, D., Monti, F., Bronstein, M., 2020. Temporal graph networks for deep learning on dynamic graphs. arXiv:2006.10637.

Safran, M., Musleh, S., 2025. PhishingGNN: Phishing email detection using graph attention networks and transformer-based feature extraction. IEEE Access 13. doi:10.1109/ACCESS.2025.3592135.

Sankar, A., Wu, Y., Gou, L., Zhang, W., Yang, H., 2020. DySAT: Deep neural representation learning on dynamic graphs via self-attention networks, in: ACM WSDM. doi:10.1145/3336191.3371845.

Shah, D., Zaman, T., 2011. Rumors in a network: Who's the culprit? IEEE Transactions on Information Theory 57, 5163–5181. doi:10.1109/TIT.2011.2158885.

Shi, F., Cao, Y., Shang, Y., Zhou, Y., Zhou, C., Wu, J., 2022. H2-FDetector: A GNN-based fraud detector with homophilic and heterophilic connections, in: The Web Conference (WWW). doi:10.1145/3485447.3512195.

Stringhini, G., Thonnard, O., 2015. That ain't you: Blocking spearphishing through behavioral modelling, in: DIMVA. doi:10.1007/978-3-319-20550-2_5.

Sturman, D., Auton, J.C., Morrison, B.W., 2025. Security awareness, decision style, knowledge, and phishing email detection: Moderated mediation analyses. Computers & Security 148. doi:10.1016/j.cose.2024.104129.

Tan, C.L., Chiew, K.L., Yong, K.S., Sze, S.N., Abdullah, J., Sebastian, Y., 2020. A graph-theoretic approach for the detection of phishing webpages. Computers & Security 95. doi:10.1016/j.cose.2020.101793.

Tang, J., Li, J., Gao, Z., Li, J., 2022. Rethinking graph neural networks for anomaly detection, in: ICML. arXiv:2205.15508.

Veličković, P., Cucurull, G., Casanova, A., Romero, A., Liò, P., Bengio, Y., 2018. Graph attention networks, in: ICLR. arXiv:1710.10903.

Vosoughi, S., Roy, D., Aral, S., 2018. The spread of true and false news online. Science 359, 1146–1151. doi:10.1126/science.aap9559.

Wang, J., Chen, P., Xu, X., Wu, J., Shen, M., Xuan, Q., Yang, X., 2022. TSGN: Transaction subgraph networks assisting phishing detection in Ethereum. arXiv:2208.12938.

Weber, M., Domeniconi, G., Chen, J., Weidele, D.K.I., Bellei, C., Robinson, T., Leiserson, C.E., 2019. Anti-money laundering in bitcoin: Experimenting with graph convolutional networks for financial forensics. arXiv:1908.02591.

Weng, Z., Zhang, W., Zhu, T., Dou, Z., Sun, H., Ye, Z., Tian, Y., 2024. RT-APT: A real-time APT anomaly detection method for large-scale provenance graph. Journal of Network and Computer Applications 233. doi:10.1016/j.jnca.2024.104036.

Wu, J., Yuan, Q., Lin, D., You, W., Chen, W., Chen, C., Zheng, Z., 2020. Who are the phishers? phishing scam detection on Ethereum via network embedding. IEEE Transactions on Systems, Man, and Cybernetics: Systems doi:10.1109/TSMC.2020.3016821.

Xu, D., Ruan, C., Korpeoglu, E., Kumar, S., Achan, K., 2020. Inductive representation learning on temporal graphs, in: ICLR. arXiv:2002.07962.

You, J., Du, T., Leskovec, J., 2022. ROLAND: Graph learning framework for dynamic graphs, in: ACM KDD. doi:10.1145/3534678.3539300.

Yu, S., Xia, W., Liu, B., Wu, J., 2023. Streaming phishing scam detection method on Ethereum. arXiv:2306.16624.

Zhang, D., Chen, J., 2021. Blockchain phishing scam detection via multi-channel graph classification. arXiv:2108.08456.

Zhang, H., Qiu, L., Yi, L., Song, Y., 2018. Scalable multiplex network embedding, in: IJCAI. doi:10.24963/ijcai.2018/428.

Zhang, M., Chen, Y., 2018. Link prediction based on graph neural networks, in: NeurIPS. doi:10.48550/arXiv.1802.09691.

Zhao, T., Zhang, X., Wang, S., 2021. GraphSMOTE: Imbalanced node classification on graphs with graph neural networks, in: ACM WSDM. doi:10.1145/3437963.3441720.